DOSSIER D'ANALYSE · TP MEHARI

Analyse des risques SSI d'Alsace Formation Numérique

23 octobre 2026 · Méthode MEHARI-Standard 2022 · Kleiton KITANI, Ryan AMORY

Version 5 · Classeur AFN_MEHARI_v04_2026-10-20.xlsm · Journal d'hypothèses v11 · Registre et feuille de route v5

1. Résumé pour la direction

AFN dispose des protections de base (antivirus, sauvegardes, accès à distance sécurisé), mais **personne ne les pilote ni ne les vérifie**. Quatre incidents l'ont déjà montré : courriel piégé, panne d'un service en ligne, fichiers mal partagés, sauvegardes non testées.

Nous avons retenu 20 scénarios d'incident, choisis pour leur gravité et leur lien avec les incidents subis. **19 sont au-dessus du seuil acceptable**, dont un « insupportable » : le vol de données par un rançongiciel. Ils forment 8 risques prioritaires.

Risque	Aujourd'hui	Dans 6 mois	Décision proposée
Rançongiciel : vol de données et postes bloqués	**4 insupportable**	**3 inadmissible**	Réduire en urgence, transférer en partie
Comptes piratés après un courriel piégé	**3 inadmissible**	**3 inadmissible**	Réduire
Données perdues, sauvegardes non restaurables	**3 inadmissible**	**2 tolérable**	Réduire
Panne d'un service en ligne pendant les formations	**3 inadmissible**	**2 tolérable**	Réduire (transfert marginal)
Fichiers partagés par erreur avec l'extérieur	**3 inadmissible**	**3 inadmissible**	Réduire
Abus de droits par une personne interne	**3 inadmissible**	**3 inadmissible**	Réduire, puis accepter 12 mois (dérogation)
Fuite par le réseau local ou un ordinateur portable	**3 inadmissible**	**3 inadmissible**	Réduire
Faux courriels au nom d'AFN (faux RIB)	**3 inadmissible**	**3 inadmissible**	Réduire

Gravité : 1–2 tolérable ; 3 inadmissible, à traiter en priorité ; 4 insupportable, mesures d'urgence. « Dans 6 mois » : protections correctement mises en œuvre.

Ce que le plan apporte. Le risque insupportable disparaît **dès le deuxième mois**. Pour 13 scénarios, la probabilité baisse de 3 ou 4 à 2 sur 4. Avec la grille actuelle, 13 scénarios restent à 3, car leur impact reste élevé ; avec le critère d'acceptation que nous proposons (impact 3 et probabilité 2 : toléré sous surveillance), aucun ne resterait inadmissible.

Ce que le plan coûte. 19 actions sur six mois, 74 jours de travail (dont 17 de prestataire) et 16 à 26 k€ de dépenses la première année.

Décisions demandées

1. Valider le plan et son budget : 74 jours de travail, dont 17 de prestataire, et 16 à 26 k€ de dépenses la première année ; le responsable IT y consacre un jour et demi par semaine pendant deux mois.
2. Lancer dès la première semaine les mesures d'urgence contre les rançongiciels : antivirus vérifié partout, copie des données hors ligne.
3. Imposer la double authentification à tous les comptes, en commençant par les administrateurs et les accès à distance.
4. Désigner un référent sécurité, confirmer les propriétaires des risques, valider la grille d'acceptation et le critère proposé, adopter la procédure de réponse aux incidents et de notification à la CNIL.
5. Accepter pour 12 mois, sous conditions, deux risques d'abus internes ; prendre acte des scénarios non évalués dans cette première analyse, évalués à six mois.
6. Faire vérifier par téléphone tout changement de coordonnées bancaires, engager la mise en conformité RGPD et faire chiffrer une assurance cyber.

2. Contexte, périmètre et hypothèses

AFN, PME fictive de 45 personnes, forme environ 1 200 apprenants par an en formations hybrides. Le LMS, le CRM, la facturation et la suite collaborative (messagerie, stockage, visioconférence) sont des services SaaS ; le NAS et quelques serveurs virtuels hébergent les fichiers bureautiques et des outils internes de suivi des dossiers, exploités par un prestataire. Le LMS, la visioconférence et la messagerie sont indispensables pendant les formations ; les moyens sont limités (journal O-01 à O-10, H-18, H-26).

Périmètre minimal (énoncé p.2)	Où il est traité
Inscription et gestion administrative	T1 domaines 1 et 2 ; RP-2, RP-3, RP-5
Formations à distance ou hybrides	T1 domaine 3, services externalisés ; RP-4
Données personnelles, contractuelles, financières	T1 domaine 9 ; RP-2, RP-5, RP-6, RP-7, RP-8 ; conformité (PGCE01)
Messagerie, stockage, LMS, accès distant	Processus 1, domaine 10 ; RP-4, RP-5, RP-8 ; accès distant : RP-2 et RP-7
Postes, comptes à privilèges, sauvegardes, réseau	Domaine 7, processus 2 ; RP-1, RP-3, RP-6 ; réseau : RP-7

Exclusions. Documents papier, archives et processus de gouvernance ne sont pas cotés ; le courrier postal est hors périmètre. Les questionnaires 7 Dev (aucun développement) et 2 Phy (hors 2D01 à 2D03) ne sont pas audités.

Hypothèses. Le cas est fictif : chaque information manquante devient une hypothèse tracée dans le journal (36 hypothèses, 86 entrées). Les plus structurantes : MFA non imposé (H-01, H-17) ; antivirus actif mais non piloté (H-16) ; sauvegarde nocturne sans test ni copie hors site (H-19) ; réseau non cloisonné et Wi-Fi des apprenants supposé non séparé (H-20) ; comptes génériques et formateurs sur ordinateur personnel (H-21) ; contrats SaaS aux conditions générales (H-24) ; RIB échangés par courriel sans authentification du domaine (H-30) ; objectifs de reprise : 4 heures pour les services de formation, 1 jour pour le NAS, 24 heures de données perdues au plus (H-31).

Hypothèse principale	Effet dans l'analyse	À valider par
H-01, H-17 MFA disponible mais non imposé	3A07 à 0, 3A09 = 0,8 ; RP-2	Responsable IT
H-16 Antivirus actif, rien de piloté	4A02 = 0,92 ; RP-1	Responsable IT
H-18 LMS, CRM, facturation en SaaS ; outils internes sur serveurs virtuels	Données SaaS en D07, outils internes en D01	Responsable IT
H-19 Sauvegarde nocturne sans test ni copie hors site	4A03 = 0,8 ; RP-3, A05, A13	Exploitation
H-20 Réseau non cloisonné, Wi-Fi des apprenants non séparé	DBUC05 retenu sous condition ; RP-7	Prestataire réseau
H-21 Comptes génériques ; formateurs sur ordinateur personnel	3A02, 3A06, 6C02 à 0 ; RP-6, RP-7	Responsable IT, RH
H-24 Contrats SaaS aux conditions générales	5D02, 4A04 à 0 ; RP-4	Direction
H-26 Responsable IT à temps partiel ; prestataire administrateur du NAS	Charge du plan ; A11 ; DAPC01-c	Direction
H-30 RIB échangés par courriel, domaine non authentifié	6B03 à 0 ; CEPI02 ; RP-8, A18	Responsable IT, finances
H-31 Reprise : 4 h pour la formation, 1 jour pour le NAS, 24 h de données au plus	Indicateurs de A05, A06, A07	Direction

Cadre réglementaire. AFN est a priori hors du champ de NIS2 : moins de 50 salariés, et la formation professionnelle ne figure pas parmi les secteurs visés (H-35, à vérifier). Le RGPD est le cadre principal : registre des traitements, encadrement des éditeurs SaaS comme sous-traitants (art. 28), transferts hors UE, durées de conservation, dont la suppression des comptes d'apprenants sortis (H-22, H-36). Ces points sont traités par l'action A19.

3. Méthode suivie et limites

Nous avons suivi le cycle MEHARI rappelé par l'énoncé avec le classeur MEHARI-Standard 2022 Éd. 2.1 du CLUSIF, en versions datées (version rendue : v04 du 20/10/2026). Rôles : Kleiton KITANI pilote l'analyse et porte le diagnostic et les risques ; Ryan AMORY porte les actifs et enjeux et la restitution.

- **Enjeux** : 13 lignes cotées en D, I, C dans T1 et T2 (7 domaines d'activité, 3 lignes reprenant le périmètre imposé, 2 processus transverses). Données SaaS classées en données externalisées, outils internes en données applicatives.
- **Diagnostic** : variante V1 ; 300 questions sur 35 sous-services ; « oui » si la mesure est établie par l'énoncé ou une hypothèse tracée, « non » sinon (R-21). La correspondance avec la note de 0 à 4 de l'étape 15 est soumise à l'enseignant (Q-01).
- **Exposition** : valeurs standard. L'hameçonnage reste à 3 faute de donnée de fréquence ; la répétition des incidents plaide pour 4 (H-23) : le responsable IT comptera les incidents au mois 1, et le test à 4 est présenté section 6.
- **Scénarios et traitement** : 20 scénarios retenus sur 183, un par levier de réduction, chacun répondant aux trois questions de l'énoncé ; 12 projets décidés, avec des niveaux cibles fixés à 3 dans le classeur rendu, pour montrer ce qui est atteignable en six mois ; 19 actions, renvoyées dans Plans_action (colonne AL).

Deux échelles distinctes

Impact	Énoncé (étape 9)	Exemple pour AFN (H-25)
1	Faible	Gêne interne vite corrigée
2	Modéré	Site vitrine indisponible quelques jours ; retard de facturation
3	Important	Session de formation reportée ; fuite de données personnelles à notifier à la CNIL ; dossiers de financement faux ou perdus ; paiement détourné
4	Critique	Survie d'AFN en jeu : interruption de plus d'une semaine en période de formation ; perte des financements ou de la certification Qualiopi. Aucun actif n'atteint ce niveau.

La **gravité** d'un scénario combine cet impact et sa **potentialité** (probabilité, de 1 à 4) selon la grille du classeur, identique à celle du guide : 1–2 tolérable, 3 inadmissible, 4 insupportable. Le rançongiciel est de gravité 4 parce que sa potentialité est maximale, alors que son impact est 3 : il ne menace pas la survie d'AFN, mais il est urgent. La grille appartient à l'organisation et n'a pas encore été validée par la direction (M-12) : nous proposons de tolérer sous surveillance l'impact 3 associé à une potentialité 2 (H-34).

Limites

1. **Un diagnostic qui reflète nos hypothèses.** 286 réponses sur 300 sont « non », parce que la plupart des hypothèses décrivent une mesure absente ; seuls 35 sous-services sur 153 sont audités. Deux réponses sont même à revoir (O-26). Saisir l'échelle de l'énoncé en note directe donne exactement le même résultat (O-16), mais le diagnostic ne distingue pas les services entre eux : c'est la première chose à confirmer avec le responsable IT.
2. **Le plancher du classeur.** Le niveau d'un sous-service ne descend jamais sous 1 : la gravité actuelle reste égale à la gravité intrinsèque.
3. **Des mesures sans effet sur les scénarios.** La réponse à incident (4D02), la sensibilisation (1C03), les départs (1C05), les vulnérabilités (4A06) ou les fournisseurs (1F01 à 1F04) existent dans la base mais ne pilotent aucun scénario retenu ; les règles de partage, le moindre privilège et la corbeille des services SaaS n'y sont pas. Leur effet est estimé hors classeur (H-27, H-32).
4. **Un ordre inversé et une hypothèse réseau.** L'audit a suivi la sélection des scénarios, alors que MEHARI diagnostique d'abord (O-21). DBUC05 n'a de sens que si le Wi-Fi des apprenants n'est pas séparé (H-20).
5. **Des contraintes du modèle.** Risk%event ne compte que 6 scénarios (O-19) ; le Tbord présente l'évolution par années (O-23) ; des défauts hérités sont sans effet sur les résultats (O-20).

4. Actifs et enjeux de sécurité

Les enjeux les plus élevés portent sur les données des outils internes et les données stockées dans le cloud (3 en disponibilité, intégrité et confidentialité), puis sur la disponibilité des services externalisés et sur la messagerie (3 en disponibilité et en intégrité). Classification d'ensemble (D, I, C) : outils internes et données cloud 3, 3, 3 ; fichiers bureautiques 2, 2, 3 ; courrier électronique 3, 3, 2 ; données publiées 2, 2 ; services externalisés 3, 2 ; services applicatifs internes 2, 2.

Niveau 3	Où (T1, T2)	Conséquence redoutée	Source
C = 3	Outils internes (domaines 2, 9), données cloud (1, 2, 5, 9, processus 1), fichiers bureautiques (6, 9)	Exposition de données personnelles et financières	Énoncé p.3 ; J-05
I = 3	Outils internes et cloud (2, 9), émargements (4), messagerie (processus 1)	Dossiers faux ; émargements falsifiés ; faux RIB au nom d'AFN	Énoncé p.3 ; J-06, J-10, J-11
D = 3	Données cloud et messagerie (3) ; services externalisés (3, processus 1)	Formations interrompues pendant une session	Énoncé p.2 ; J-01
D = 3	Outils internes (2) ; données cloud (2, 9, processus 2)	Dossiers inaccessibles, restauration impossible	Énoncé p.3 ; J-07, J-09

Activités majeures et dysfonctionnements redoutés (étapes 7 et 8)

Activité (T1)	Acteurs, entrées → résultats	Dépendances numériques	Dysfonctionnements redoutés
1 Prospection et inscription	Apprenants, personnel administratif ; identités, coordonnées → apprenant inscrit	CRM (SaaS), messagerie, services en ligne	Retard d'inscription ; erreur de saisie ; divulgation d'identités
2 Gestion administrative et financement	Personnel administratif, financeurs ; inscription → dossier de financement, contrat	Outils internes (serveurs virtuels), messagerie, stockage cloud	Dossier faux ou perdu ; retard de prise en charge ; divulgation ; non-conformité
3 Délivrance des formations	Formateurs, apprenants ; contenus → sessions	LMS, visioconférence, messagerie (SaaS)	Indisponibilité pendant une session ; contenus altérés ; accès non autorisés
4 Évaluation et attestation	Formateurs, apprenants ; émargements, évaluations → attestations	LMS ; émargements numériques (H-07)	Émargements perdus ou falsifiés : refus de prise en charge
5 Facturation et encaissement	Personnel, financeurs, clients ; contrats, présences → factures, paiements	Facturation (SaaS) ; messagerie (factures, RIB)	Facture erronée ; paiement détourné par un faux RIB

Les domaines 7, 9, 10 et le processus 2 de T1 ne sont pas des activités métier : ils reprennent le périmètre imposé et ne modifient pas la classification, qui retient le maximum de chaque colonne (O-14).

5. Services de sécurité et principaux écarts

Les 35 sous-services audités finissent au niveau 1, sauf 6B04 (niveau 2). Sur l'échelle de l'énoncé, l'existant se répartit ainsi (O-16) :

Groupe	Énoncé	Sous-services et constat
En place mais non piloté	2	4A02 antivirus sans console ni correctifs serveurs ; 4A03 sauvegarde sans test ni copie hors site ; 6B04 synchronisation des postes ; 5B01 TLS vers le SaaS, flux internes en clair
Partiel	1	3A04 mot de passe seul ; 3A09 MFA disponible non imposé ; 1B02 VPN sans encadrement
Absent	0	1C06 anti-hameçonnage, 3A07 authentification forte, 3A08 journalisation, 4A04 copie des données SaaS, 5D02 repli, 6B01 chiffrement des disques, 6B03 authentification des courriels, 6C02 ordinateurs personnels

Les questions de MEHARI portent surtout sur le pilotage, la vérification et la copie hors site, que l'existant n'assure pas. Le plan franchit donc deux marches : **piloter et vérifier l'existant** (A04, A05, A13) et **créer ce qui manque** (A02, A03, A07, A14, A18). La feuille « Score ISO 27002 » du classeur confirme ce constat : seules 6.7, 8.5, 8.7 (3,3 sur 10) et 8.13 (5) ont un score. Les 12 projets fixent un objectif de 3 pour 25 sous-services (annexe C).

6. Registre des risques et risques prioritaires

Sur les 20 scénarios retenus, 19 sont inadmissibles aujourd'hui, dont un insupportable. Ce ratio décrit notre sélection, centrée sur les scénarios graves, pas l'ensemble du système d'information. Ils forment 8 risques prioritaires, numérotés par gravité ; chacun a un propriétaire métier. Le détail par scénario est en annexe A et dans le registre (v5).

Risque	Scénarios (MEHARI)	Gravité : actuel → 6 mois	Potentialité : actuel → 6 mois	Décision	Propriétaire
RP-1	Rançongiciel : vol de données et postes bloqués (DBUC04, DBUD03, SAPD24)	4 → 3	4 → 2	Réduire en urgence, transférer en partie	Direction
RP-2	Comptes piratés après un courriel piégé (DBUC03, DAPC01-b, DAPI01-a)	3 → 3	3 → 2	Réduire	Direction
RP-3	Données perdues, sauvegardes non restaurables (DAPD02, DEXD01)	3 → 2	3 → 3	Réduire	Direction administrative et financière
RP-4	Panne d'un service en ligne pendant les formations (SEXD02, CEPD02 (SEXD01 regroupé))	3 → 2	3 → 3	Réduire (transfert marginal)	Responsable pédagogique
RP-5	Fichiers partagés par erreur avec l'extérieur (DBUC02, DEXC01)	3 → 3	3 → 2	Réduire	Direction administrative et financière
RP-6	Abus de droits par une personne interne (DAPC01-a, DAPI01-b, DAPD03)	3 → 3	3 → 2	Réduire, puis accepter 12 mois (dérogation)	Direction
RP-7	Fuite par le réseau local ou un ordinateur portable (DBUC05, DBUC01-e, DBUC10-b)	3 → 3	3 → 2	Réduire	Direction
RP-8	Faux courriels au nom d'AFN (faux RIB) (CEPI02)	3 → 3	3 → 2	Réduire	Direction administrative et financière

Aujourd'hui	P 1	P 2	P 3	P 4
Impact 4	G2	G3	G4	G4
Impact 3	G2	**2 scén. · G3**	**14 scén. · G3**	**1 scén. · G4**
Impact 2	G1	**1 scén. · G2**	G2	**2 scén. · G3**
Impact 1	G1	G1	G1	G2

Dans 6 mois	P 1	P 2	P 3	P 4
Impact 4	G2	G3	G4	G4
Impact 3	G2	**13 scén. · G3**	G3	G4
Impact 2	G1	**3 scén. · G2**	**4 scén. · G2**	G3
Impact 1	G1	G1	G1	G2

Les 20 scénarios retenus, acceptés compris : nombre de scénarios et gravité de chaque case (G1 à G4, répétée par la couleur). Le plan déplace les scénarios vers la gauche (probabilité) ; les 13 restants sont tous en impact 3 et potentialité 2.

Analyse des risques prioritaires

RP-1 Rançongiciel (4 → 3). Le seul scénario insupportable (DBUC04) est le volet fuite : exfiltration avant chiffrement. Mesures d'urgence dès la semaine 1 (A13), puis antivirus piloté et correctifs (A04) : il quitte le niveau 4 au mois 2. Le volet destruction (DBUD03, SAPD24 et, hors sélection, DAPD01-b) descend à 2 grâce aux sauvegardes testées et hors ligne (A05).

RP-2 Comptes piratés (3 → 3). Incident déjà subi. Le MFA et la procédure anti-hameçonnage (A02, A03) font passer la potentialité de 3 à 2 ; l'impact reste 3, d'où la gravité 3 avec la grille actuelle.

RP-3 Sauvegardes (3 → 2) et RP-4 Panne SaaS (3 → 2). Ici le plan réduit l'impact : sauvegardes testées et copie quotidienne des données cloud (A05, A06), mode dégradé activé en moins de 4 heures (A07). Pour RP-4, le transfert est marginal : une PME n'obtient guère d'engagement négocié d'un éditeur SaaS, et une assurance cyber couvre rarement une panne du fournisseur.

RP-5 Partage par erreur (3 → 3). L'erreur ouvre l'accès (DBUC02) ; un tiers peut ensuite télécharger volontairement les données par un lien ou un compte d'ancien apprenant resté ouvert (DEXC01). Les règles de partage (A08) ne sont pas modélisées : leur effet est estimé au niveau 2 (R-23).

RP-6 Abus de droits (3 → 3). La base ne prévoit que la dissuasion. Options examinées : double validation des dossiers de financement (séparation des tâches) contre la falsification, restriction des exports contre la diffusion, sauvegardes immuables contre la destruction. Même avec le moindre privilège (A01, A10), la gravité reste 3 (H-32). Nous proposons d'accepter DAPC01-a et DAPI01-b 12 mois, par dérogation. Sortie : PIDA pour DAPI01-b (phase 2) ; pour DAPC01-a, la base n'offre aucune sortie : la restriction des exports sera évaluée avant la décision de M12.

RP-7 Réseau et postes nomades (3 → 3) : Wi-Fi des apprenants supposé non séparé (DBUC05), ordinateurs personnels des formateurs, vol de portable ; CHED, SAMP et CHDB. **RP-8 Faux RIB (3 → 3)** : un fraudeur écrit au nom d'AFN à un financeur ; le levier est l'authentification du domaine (SPF, DKIM, DMARC) et la vérification des RIB par téléphone (A18).

Risque résiduel

Scénarios retenus	Aujourd'hui	Fin mois 2	Fin mois 4	Fin mois 6	Lecture
Gravité 4	1	0	0	0	Disparaît au mois 2
Gravité 3	18	16	13	13	Tous en impact 3, potentialité 2
Gravité 1 ou 2	1	4	7	7	

Avec la grille actuelle, 13 scénarios restent à 3 après six mois. Tous sont en impact 3 et potentialité 2 : un plan surtout préventif baisse la probabilité, pas l'impact. **Avec le critère proposé** (H-34), ils seraient tolérés sous surveillance de leur propriétaire. À plus long terme, des protections matures (niveau 4) ramèneraient le nombre à 2, mais ce n'est qu'un horizon : la phase 2 n'est ni décidée ni chiffrée.

Hors sélection, 56 scénarios sont de gravité 3 ; 38 le restent après le plan, dont 3 hors périmètre. Nous ne demandons pas de les accepter : beaucoup ne sont à 3 que parce que leurs services ne sont pas audités. Ils sont listés un par un dans le registre (onglet « Risques résiduels ») comme **non évalués dans cette itération**, et seront évalués à M6. C'est le cas de la fuite lors d'une maintenance par le prestataire (DAPC01-c), que le projet COMA ramènerait à 2.

Test de sensibilité. Avec une exposition à l'hameçonnage de 4 (H-23), DBUC03 passe à 4 : il y aurait deux risques insupportables aujourd'hui. Le plan ne change pas (A02 et A03 sont en P1). **Vue par événement** (étape 20, Risk%event étant défectueux) : malveillance logique 10 (vol de données 4, falsification 2, captation, hameçonnage, faux courriel et destruction 1 chacun), erreurs de manipulation 3, logiciels malveillants 3, défaillance de prestataire 2, vol physique 1, procédure absente 1.

7. Plan de traitement et feuille de route

19 actions en 6 lots, 12 projets MEHARI, six mois à partir de la validation (M0 supposé le 02/11/2026). 8 actions P1 (mois 1–2), 11 actions P2 (mois 2–6) ; aucune n'est d'un coût élevé. **Budget** : 74 jours-homme, dont 17 de prestataire à 700 € (≈ 12 k€) et 57 internes (≈ 20 k€ à 350 € chargés, coût d'opportunité) ; dépenses externes 16 à 26 k€ la première année, dont 3 à 11 k€ récurrents, hors licences MFA si elles ne sont pas incluses. Les P1 demandent environ 13 jours internes sur deux mois, soit un jour et demi par semaine partagé entre le responsable IT et la direction.

Action	Risques	Responsable	Priorité	Échéance	ISO 27002
A13 Mesures d'urgence (semaines 1–2) (2 j·h)	RP-1, RP-3	Responsable IT ; Exploitation	P1	S1–S2	8.7, 8.13
A01 Inventaire des comptes et des droits (3 j·h)	RP-2, RP-6	Responsable IT	P1	M1	5.15, 5.16, 5.18
A02 MFA : privilèges, accès distants, cloud (3 j·h)	RP-2, RP-5	Responsable IT	P1	M1–M2	5.17, 8.5
A03 Procédure anti-hameçonnage, sensibilisation (3 j·h)	RP-2, RP-1	Direction (pilotage) ; Responsable IT (contenu)	P1	M1–M2	6.3, 6.8
A04 Anti-malware et correctifs (5 j·h)	RP-1	Responsable IT / Exploitation	P1	M1–M2	8.7, 8.8
A05 Sauvegarde testée, copie hors ligne (5 j·h)	RP-3, RP-1	Exploitation	P1	M1–M2	8.13
A14 Réponse aux incidents, CNIL (3 j·h)	RP-1, RP-2, RP-5, RP-7	Direction ; Responsable IT	P1	M1–M2	5.24, 5.25, 5.26, 6.8
A12 Référent SSI, validations, réévaluation (15 j·h)	Tous	Direction	P1	M1–M6	5.2, 5.4
A08 Règles de partage cloud (2 j·h)	RP-5	Référent SSI ; Responsable IT	P2	M2	5.10, 5.14
A09 Chiffrement des portables (3 j·h)	RP-7, RP-1, RP-5	Responsable IT	P2	M2–M3	8.1, 8.24
A10 Politique d'accès et de départs (3 j·h)	RP-6, RP-2, RP-5	Direction / RH / IT	P2	M2–M3	5.15, 5.18
A15 Flux NAS chiffrés, Wi-Fi séparé (3 j·h)	RP-7	Responsable IT ; prestataire réseau	P2	M2–M3	8.20, 8.22, 8.24
A16 Charte des postes des formateurs (2 j·h)	RP-7	Direction / RH ; Responsable IT	P2	M2–M3	6.7, 8.1
A18 Authentification des courriels, RIB vérifiés (2 j·h)	RP-8	Responsable IT ; Direction administrative et financière	P2	M2–M3	5.14
A06 Copie quotidienne des données cloud (3 j·h)	RP-3, RP-4	Exploitation (copie) ; Direction (contrats)	P2	M2–M4	8.13, 5.23
A07 Mode dégradé des services SaaS (5 j·h)	RP-4	Direction ; Responsable IT	P2	M3–M4	5.23, 5.30
A17 Étude d'une assurance cyber (2 j·h)	RP-1, RP-2, RP-4	Direction	P2	M3–M4	— (transfert)
A19 Conformité RGPD, NIS2, financeurs (5 j·h)	Hors RP (PGCE01)	Direction ; Référent SSI	P2	M2–M4	5.31, 5.34, 5.36
A11 Journalisation des privilèges (prestataire compris) (5 j·h)	RP-6	Responsable IT (mise en place) ; Direction (revue)	P2	M3–M6	8.2, 8.15, 8.16

Indicateurs, prérequis, coûts et planning mensuel : feuille de route du fichier de pilotage ; renvoi par projet dans Plans_action (colonne AL).

Choix des projets. Avec des cibles à 3, la gravité calculée ne baisse que pour les scénarios dont l'impact ou la probabilité diminue assez : sauvegardes (SADC, DIDE), continuité (PSSE, SMEL), anti-malware (PMAL). Les autres projets font baisser la probabilité sans changer la gravité : CASA, CASE, SAMP, SUAI, CHDB et SMEL ramènent la potentialité de 3 à 2. CHED et CPEX n'ont d'effet calculé qu'avec une cible à 4 : ils sont maintenus, l'un pour le réseau du périmètre minimal, l'autre pour la conformité légale. SADC reste le plus efficace sur la base complète (13 scénarios de niveau 3 ramenés à 2). Les quatre projets que Sel_Projets propose encore (PIDA, CHDA, PCDE, SUBU), plus COMA pour le prestataire, forment une phase 2 (mois 7 à 12), à décider et chiffrer à M6.

Stratégies (étape 22). Réduire les 8 risques ; transférer en partie RP-1 (assurance cyber) ; accepter seulement deux scénarios de RP-6. PGCE01 (non-conformité) n'est pas accepté : une obligation légale se traite (CPEX, A19). Évitement : la désactivation par défaut des liens publics (A08) supprime une pratique plutôt qu'elle ne la protège.

8. Décisions, acceptations et suivi

Décisions attendues de la direction

1. Valider le plan et son budget : 74 jours de travail, dont 17 de prestataire, et 16 à 26 k€ de dépenses la première année ; le responsable IT y consacre un jour et demi par semaine pendant deux mois.
2. Lancer dès la première semaine les mesures d'urgence contre les rançongiciels : antivirus vérifié partout, copie des données hors ligne.
3. Imposer la double authentification à tous les comptes, en commençant par les administrateurs et les accès à distance.
4. Désigner un référent sécurité, confirmer les propriétaires des risques, valider la grille d'acceptation et le critère proposé, adopter la procédure de réponse aux incidents et de notification à la CNIL.
5. Accepter pour 12 mois, sous conditions, deux risques d'abus internes ; prendre acte des scénarios non évalués dans cette première analyse, évalués à six mois.
6. Faire vérifier par téléphone tout changement de coordonnées bancaires, engager la mise en conformité RGPD et faire chiffrer une assurance cyber.

Risque accepté	Niveau, durée	Conditions, surveillance et sortie
DAPC01-a Diffusion de données par un utilisateur autorisé	3, 12 mois (dérogation)	Droits inventoriés (A01), politique d'accès (A10), revue trimestrielle des droits, synthèse mensuelle des journaux, prestataire compris (A11) ; réexamen à M6. Pas de sortie dans la base : restriction des exports à évaluer avant M12. Propriétaire : la direction
DAPI01-b Falsification de données par un utilisateur autorisé	3, 12 mois (dérogation)	Mêmes conditions ; sortie : double validation des dossiers et projet PIDA (phase 2), qui le ramène à 2

Ces acceptations sont saisies « A » en colonne AA de la feuille Scénarios (guide p.48) et doivent être approuvées par leur propriétaire (cours ; ISO/IEC 27001 §6.1.3).

Mesurer le progrès dans six mois

1. **Réalisation** : comptes sous MFA (100 %), équipements protégés et à jour (100 %), un test de restauration réussi par trimestre, aucun lien public non justifié, formateurs signataires, DMARC publié.
2. **Maturité** : questionnaires repassés en confirmant ou corrigeant les hypothèses, diagnostic étendu aux sous-services non audités ; 1C06, 3A07, 4A02, 4A03, 4A04, 5D02, 6B03, 6C02 et 8A01 au moins à 3 ; score ISO recalculé.
3. **Risque** : gravité recalculée dans le classeur ; cibles : aucun niveau 4, au plus 13 scénarios retenus à 3, potentialité ramenée à 2 ; scénarios non évalués évalués ; décision sur le critère d'acceptation et sur la phase 2.

Annexes

A. Scénarios retenus : les trois questions de l'énoncé

Scénario	RP	Actif touché	Événement ou acteur	Conséquence métier	I·P·G actuels	I·P·G à 6 mois	G à terme
DBUC04	RP-1	Fichiers bureautiques sur le NAS et les postes (T1 domaines 6 et 9, C = 3)	Logiciel malveillant, dont rançongiciel à double extorsion (IF.L.Vir) ; exposition naturelle 4 (valeur standard)	Fuite (exfiltration) de données RH et personnelles par le logiciel malveillant : volet confidentialité de RP-1, seul scénario de niveau 4	3·4·4	3·2·3	**2**
DBUD03	RP-1	Fichiers bureautiques partagés (NAS) et fichiers des postes (D02, D = 2)	Virus ou logiciel malveillant (IF.L.Vir) ; exposition naturelle 4	Fichiers effacés : travail administratif à reconstituer	2·4·3	2·2·2	**1**
SAPD24	RP-1	Postes de travail des salariés et formateurs (T2 S01, D = 2)	Logiciel malveillant, rançongiciel (IF.L.Vir) ; exposition naturelle 4	Postes inutilisables : arrêt du travail administratif et des formations dispensées depuis ces postes	2·4·3	2·2·2	**1**
DBUC03	RP-2	Fichiers bureautiques et courriels (données RH, données personnelles : T1 domaines 6 et 9, C = 3)	Salarié ou formateur trompé par un message d'hameçonnage (AH.L.Phi)	Divulgation de données personnelles d'apprenants ou de salariés	3·3·3	3·2·3	**2**
DAPC01-b	RP-2	Données des outils internes hébergés sur les serveurs virtuels : dossiers administratifs et de financement, contrats (T1 domaines 2 et 9, C = 3)	Tiers non autorisé (AH.L.Vol) ; interprétation : il se connecte par le VPN avec un compte volé par hameçonnage (H-05)	Exposition de dossiers de financement et de données personnelles d'apprenants	3·3·3	3·2·3	**2**
DAPI01-a	RP-2	Données des outils internes (serveurs virtuels) : dossiers administratifs et de financement (T1 domaines 2 et 9, I = 3)	Personne non autorisée (AH.L.Fal) ; interprétation : via un compte usurpé, joint par le VPN	Dossiers administratifs ou de financement altérés : erreurs administratives, retard de prise en charge	3·3·3	3·2·3	**2**
DAPD02	RP-3	Données des outils internes (serveurs virtuels) : dossiers administratifs et de financement (T1 domaine 2, D = 3), sauvegardées avec le NAS (H-19)	Erreur de manipulation ou de procédure (ER.P.Pro)	Perte de dossiers administratifs ou de financement ; restauration incertaine	3·3·3	2·3·2	**2**
DEXD01	RP-3	Données externalisées sur le cloud : LMS, CRM, facturation, stockage collaboratif (T1 domaines 1 à 5, 9, processus 1 et 2, D = 3)	Effacement accidentel (ER.P.Pro)	Perte de contenus de formation, de suivis ou de dossiers stockés chez le prestataire, sans copie indépendante vérifiée	3·3·3	2·3·2	**2**
SEXD02	RP-4	Services externalisés : LMS, visioconférence, messagerie (T2 S02 domaine 3 et processus 1, D = 3)	Panne de l'infrastructure du prestataire (AB.S.Ser) ; inclut l'absence du prestataire (SEXD01, regroupé : même actif, même gravité, même traitement)	Formations en cours interrompues	3·3·3	2·3·2	**2**

Scénario	RP	Actif touché	Événement ou acteur	Conséquence métier	I·P·G actuels	I·P·G à 6 mois	G à terme
CEPD02	RP-4	Messagerie électronique (T1 domaine 3 et processus 1, D = 3)	Indisponibilité des services du partenaire de messagerie (AB.S.Ser)	Échanges avec les apprenants et formateurs bloqués pendant les sessions	3·3·3	2·3·2	**1**
DBUC02	RP-5	Fichiers bureautiques : données RH et personnelles (T1 domaines 6 et 9, C = 3)	Erreur de manipulation : envoi ou partage au mauvais destinataire (ER.P.Pro)	Exposition de données personnelles	3·3·3	3·2·3	**2**
DEXC01	RP-5	Données externalisées sur le cloud : dossiers apprenants, LMS, CRM (T1 domaines 1 à 5, 9, C = 3)	Téléchargement volontaire (AH.L.Vol) ; interprétation : via un lien de partage mal configuré, un compte cloud volé ou le compte d'un ancien apprenant resté actif (H-22)	Divulgation de dossiers apprenants	3·3·3	3·2·3	**2**
DAPC01-a	RP-6	Données des outils internes (serveurs virtuels), D01, C = 3	Utilisateur autorisé, dont personnel à droits privilégiés (AH.L.Vol)	Fuite de dossiers de financement ou de données personnelles par un initié	3·3·3	3·2·3	**3**
DAPI01-b	RP-6	Données des outils internes (serveurs virtuels), D01, I = 3	Utilisateur autorisé, dont personnel à droits privilégiés (AH.L.Fal)	Falsification de dossiers ou de résultats par un initié	3·3·3	3·2·3	**3**
DAPD03	RP-6	Données des outils internes et leurs sauvegardes sur le NAS (D01, D = 3)	Membre du personnel doté de droits privilégiés (AH.L.Tot)	Destruction des données et de leurs sauvegardes : reprise impossible	3·2·3	3·2·3	**2**
DBUC05	RP-7	Fichiers bureautiques échangés entre les postes et le NAS sur le réseau local : fichiers RH, dossiers d'apprenants (T1 domaines 6 et 9, C = 3)	Écoute du réseau local par une personne connectée au Wi-Fi non séparé, par exemple un apprenant en présentiel (AH.L.Cap) ; scénario conditionnel à H-20	Divulgation de données RH ou d'apprenants captées en transit	3·2·3	3·2·3	**2**
DBUC01-e	RP-7	Fichiers bureautiques et données d'apprenants consultés depuis les ordinateurs personnels des formateurs extérieurs (T1 domaines 6 et 9, C = 3)	Proche d'un formateur ou d'un télétravailleur qui utilise le même ordinateur personnel (AH.L.Vol)	Divulgation de données personnelles d'apprenants	3·3·3	3·2·3	**2**
DBUC10-b	RP-7	Portables des salariés contenant des fichiers RH et des dossiers d'apprenants (T1 domaines 6 et 9, C = 3)	Vol ou perte d'un portable (AH.P.Vol) ; la base n'a pas de scénario de vol hors des locaux (H-28)	Divulgation des données présentes sur le disque du portable	3·3·3	3·2·3	**2**
CEPI02	RP-8	Messagerie d'AFN : échanges de factures, de conventions et de coordonnées bancaires avec les financeurs, les entreprises clientes et les apprenants (T1 processus 1, I = 3 ; domaine 5)	Fraudeur qui envoie des courriels au nom d'AFN en usurpant son domaine (AH.L.Fau)	Faux RIB envoyé à un financeur ou à un client : paiement détourné, retard d'encaissement, atteinte à la relation avec les financeurs	3·3·3	3·2·3	**2**
PGCE01	Hors RP	Processus de gestion de la conformité (T2 P01, E = 2 : domaines 1, 2, 5, 6, 9)	Procédure absente ou ignorée (PR.N.Nai)	Non-respect d'une obligation légale ou contractuelle (données personnelles, financements)	2·2·2	2·2·2	**1**

I · P · G : impact, potentialité, gravité (feuille Scénarios, col. X, Y, Z). « À 6 mois » : classeur rendu, cibles à 3. « À terme » : copie, cibles à 4 (horizon non budgété).

B. Résultats des questionnaires (variante V1)

Code	Sous-service	Questions	Note V1	Niveau final
1B02	Utilisation des mobiles et télétravail	3	1	1
1B05	Cloisonnement des réseaux	3	0	1
1B07	Sécurité de l'information dans l'utilisation de services en nuage	2	0	1
1C06	Protection contre l'hameçonnage (phishing) et abus de confiance	5	0	1
1E01	Plans de continuité de l'activité	17	0	1
1E03	Gestion du personnel et des partenaires ou prestataires stratégiques	8	0	1
2D01	Contrôle d'accès physique aux zones de bureaux sensibles	16	0	1
2D02	Détection des intrusions dans les zones de bureaux protégées	8	0	1
2D03	Surveillance des zones de bureaux protégées	7	0	1
3A02	Gestion des autorisations d'accès (attribution, délégation, retrait)	14	0	1
3A03	Informations d'authentification	2	0	1
3A04	Contrôle des accès (aux applications, aux données applicatives et aux fonctions systèmes)	26	0,21	1
3A06	Gestion des autorisations d'accès privilégiés (attribution, délégation, retrait)	11	0	1
3A07	Contrôle des accès privilégiés	4	0	1
3A08	Surveillance des actions effectuées avec des droits privilégiés	10	0	1
3A09	Contrôle d'accès aux systèmes et services externalisés	6	0,8	1
4A02	Protection contre les malwares	9	0,92	1
4A03	Sauvegarde des données et configurations	17	0,8	1
4A04	Sauvegarde de recours des données externalisées	11	0	1
4A10	Surveillance en temps réel de l'activité et gestion des anomalies	9	0	1
4A11	Journalisation et contrôle des journaux	13	0	1
5A02	Protection de l'intégrité des fichiers de données applicatives sensibles	7	0	1
5A03	Contrôles permanents (vraisemblance, ...) sur les données et traitements	6	0	1
5B01	Chiffrement des échanges de données applicatives	4	1	1
5B02	Chiffrement des données applicatives stockées	6	0	1
5D02	Plan de continuité des services externalisés	6	0	1
5G02	Chiffrement des données applicatives externalisées	5	0	1
6A02	Travail en dehors des locaux de l'entreprise	7	0	1
6A03	Plan de continuité de la messagerie électronique	5	0	1
6B01	Protection de la confidentialité des données contenues sur le poste de travail ou sur un serveur de données (disque logique pour le poste de travail)	8	0	1
6B03	Sécurité de la messagerie électronique (courriels) et des échanges électroniques d'information	9	0	1
6B04	Plan de sauvegardes des données utilisateurs stockées sur les postes de travail	5	1,6	2
6B07	Sauvegarde des configurations des postes de travail des utilisateurs	11	0	1

Code	Sous-service	Questions	Note V1	Niveau final
6C02	Dispositifs de sécurité relatifs aux appareils mobiles personnels	5	0	1
8A01	Mise en place des processus et procédures adaptés aux exigences légales ou contractuelles	15	0	1

C. Choix des projets MEHARI

Chaque projet est marqué décidé seul, à partir de l'état actuel (copie du classeur v04, cibles à 3) : la colonne « Effet » indique les scénarios retenus dont la gravité (G), la potentialité (P) ou l'impact (I) baisse.

Projet	Services → cible	Effet sur les retenus (projet seul)	Décision	Rôle dans le plan
PMAL	1C06 0→3 ; 4A02 1→3	DBUD03 (G 3→2), DBUC03 (P 3→2), DBUC04 (G 4→3), SAPD24 (G 3→2)	Retenu	Projet qui réduit le plus de scénarios retenus, dont le seul niveau 4 ; répond à l'incident d'hameçonnage.
CASA	3A02 0→3 ; 3A04 0→3 ; 3A06 0→3 ; 3A07 0→3	DAPI01-a (P 3→2), DAPC01-b (P 3→2)	Retenu	Porte le MFA et la gestion des droits demandés par l'énoncé (§7, P1 Mois 1 et P2 Mois 3). Avec une cible à 3, il fait baisser la potentialité de DAPI01-a et DAPC01-b sans changer leur gravité.
SADC	4A03 1→3 ; 6B04 2→3 ; 6B06 1→3 ; 6B07 0→3	DAPD02 (G 3→2)	Retenu	Projet le plus efficace sur la base complète (13 scénarios de niveau ≥ 3 ramenés à ≤ 2) ; répond à l'incident « sauvegardes non vérifiées ».
DIDE	3C01 1→3 ; 4A04 0→3	DEXD01 (G 3→2)	Retenu	Seul levier sur la perte de données cloud (4A04) ; H-02.
PSSE	4C04 1→3 ; 5D02 0→3	SEXD02 (G 3→2)	Retenu	Répond à l'incident d'indisponibilité SaaS et à R-03.
CASE	3A09 1→3	DEXC01 (P 3→2)	Retenu	Porte le MFA des services cloud (3A09-02, action A02) ; réduit DEXC01. Les règles de partage (A08) ne relèvent pas de 3A09 (O-15).
SUAI	3A08 0→3 ; 4A11 0→3	DAPI01-b (P 3→2), DAPC01-a (P 3→2)	Retenu	Condition de l'acceptation temporaire de RP-6 (surveillance des comptes privilégiés, prestataire compris) ; fait baisser la potentialité de DAPC01-a et DAPI01-b.
SMEL	6A03 0→3 ; 6B03 0→3	CEPD02 (G 3→2), CEPI02 (P 3→2)	Retenu	Continuité de la messagerie (6A03, CEPD02) et sécurité des courriels (6B03) : authentification du domaine contre la fraude au RIB (CEPI02, RP-8) et traitement des messages suspects.
CHDB	6B01 0→3	DBUC02 (P 3→2), DBUC04 (G 4→3), DBUC10-b (P 3→2)	Retenu	Chiffrement des disques des portables : seul levier sur DBUC10-b (H-28) ; second levier sur DBUC04 (avec PMAL). Coût faible, mois 2 à 3.
SAMP	6C02 0→3	DBUC01-e (P 3→2)	Retenu	Seul projet qui réduit DBUC01-e (ordinateurs personnels des formateurs).
CHED	5B01 1→3	Aucun effet calculé avec une cible à 3 ; avec une cible à 4 : DBUC05 (G 3→2)	Retenu	Seul projet qui agit sur DBUC05 (captation de fichiers sur le réseau local, conditionnel à H-20). Avec une cible à 3, la gravité calculée ne change pas : l'effet n'apparaît qu'avec une cible à 4. Maintenu parce que le réseau fait partie du périmètre minimal.
CPEX	8A01 0→3 ; 8A02 1→3 ; 8A03 1→3	Aucun effet calculé avec une cible à 3 ; avec une cible à 4 : PGCE01 (G 2→1)	Retenu	Décidé : PGCE01 (non-conformité légale) ne peut pas être accepté. Avec une cible à 3, la gravité calculée reste 2 ; avec une cible à 4, PGCE01 passe à 1.

Projet	Services → cible	Effet sur les retenus (projet seul)	Décision	Rôle dans le plan
PIDA	5A02 0→4	DAPI01-a (G 3→2), DAPI01-b (G 3→2)	Phase 2 (M7–M9)	Proposé par Sel_Projets. Réduirait DAPI01-b (RP-6) : c'est la sortie prévue de l'acceptation temporaire ; dépend de l'éditeur des outils (M-01).
CHDA	5B02 0→4	DAPI01-a (G 3→2), DAPC01-b (G 3→2)	Phase 2	Proposé par Sel_Projets (DAPI01-a, DAPC01-b). Dépend des fonctions de chiffrement des éditeurs et des outils internes (M-01).
PCDE	5G02 0→4	DEXC01 (G 3→2)	Phase 2	Proposé par Sel_Projets (DEXC01). À juger après le MFA (A02) et les règles de partage (A08), qui traitent déjà la cause.
SUBU	2D03 0→3	DBUC10-b (P 3→2)	Phase 2	Proposé par Sel_Projets (DBUC10-b). Sécurité physique des bureaux, hors de la priorité du plan à six mois.
COMA	4A09 1→4 ; 7B09 1→4	DAPC01-c, non retenu (G 3→2)	Phase 2	Contrôle des opérations de maintenance (4A09) : seul levier sur DAPC01-c (fuite lors d'une maintenance par le prestataire, H-26), aujourd'hui résiduel hors sélection.
PCAC	1E01 0→3	aucun	Non retenu (après A07)	Aucun gain calculé ; le PCA global sera bâti sur les plans de secours SaaS (A07).
GPES	1E03 0→3	aucun	Non retenu	SEXD01 (regroupé avec SEXD02) est déjà ramené à 2 par PSSE.

D. Scénarios non retenus

Catégorie	Nombre	Motif et exemples
Hors périmètre	3	Courrier postal (CEPD03-a, CEPD03-b, CEPD04)
Non évalués (actif non coté)	31	Actifs D03, D05, P02 désélectionnés
Physique ou environnement	10	Sécurité physique hors de la priorité ; DAPD12 (incendie) ramené à 2 par la copie hors site
Levier commun	23	Un projet décidé agit réellement (DBUC07 comme DBUC03, DAPD01-b par SADC) ; DAPC02 remplacé par DBUC05 ; SEXD01 regroupé avec SEXD02
Non évalués dans cette itération	20	Services non audités, plancher du niveau 1 (DAPC01-c maintenance par le prestataire, DEXC02 captation) : évaluation à M6
Gravité tolérable	76	Niveau 2, dont SAPD22 (H-20)

E. Paramétrage du classeur rendu

- T1 : données SaaS des domaines 1, 3, 4, 5 en D07 ; domaines 2 et 9 en D01 et D07 ; messagerie I = 3 (N17) ; émargements U9 = 3 ; T2 K9 = 2. Questionnaires : 300 réponses (V1) commentées.
- Scénarios : 20 sélectionnés (colonne I) ; « A » pour DAPC01-a et DAPI01-b (AA) ; colonnes V et W vides (R-23). Projets : 12 décidés, dates de la feuille de route, cibles fixées à 3 (17 cellules). Plans_action : 20 sélections (J) et renvois (AL).
- Param B3 = 2 (gravité actuelle) ; exposition et grille standard. Tbord : aujourd'hui 16 au niveau 3, 1 au niveau 4, 1 au niveau 2, plus 2 acceptés ; après le plan, 11 au niveau 3 et 7 au niveau 2, plus les 2 acceptés.

F. Sources

- Énoncé « TP MEHARI — Analyse de risques SSI » ; « Introduction aux TP » ; CLUSIF, MEHARI-Standard 2022, Guide de l'utilisateur, éd. 2 (p.15–16, 34–36, 41, 47–48).
- Cours « Cybersécurité : normes et standards », BUT3 v2026 ; ISO/IEC 27001:2022 §6.1.3 ; ISO/IEC 27002:2022 ; directive NIS2 ; RGPD.

- Classeur AFN_MEHARI_v04_2026-10-20.xlsm ; Journal_hypotheses_AFN_v11.xlsx ; AFN_Registre_risques_et_feuille_de_route_v5.xlsx.